Domain 4: Network Security

Computer Networking:

A network is simply two or more computers linked to each other to share data, information or resources.
Two basic types of networks - **(LAN) Local Area Network** & **(WAN) Wide Area Network**

Network Devices:

- **Hubs** (OSI Layer 1)
    - Wired devices and not smart as Switches or Routers.
    - Known for broadcasting.

- **Switch** (OSI Layer 2)
    - Known as intelligent hub.
    - Wired devices that know the address of the devices connected to them and route traffic to port / device rather than retransmitting to all devices.
    - Improves overall throughput of data.
    - Can create separate broadcast domains when used to create VLANs.

- **Router** (OSI Layer 3)
    - Used to connect similar networks and control traffic flow.
    - Can be wired or wireless and can connect multiple switches.
    - Smarter than hubs and switches, determines most efficient route for traffic flow.

- **Firewall** (OSI Layer 2, 3, 4 and 7)
    - Manages and controlls network traffic and protects the network.
    - Typically deployed between private network and internet.
    - Can also deployed between departments (segmented networks) within an organization (overall network).
    - Filters traffic based on set of rules or Access Control lists.

- **Server**
    - Provides information to other computers on a network.
    - Some common srevers are Web servers, Email servers, Print servers, database servers.
    - Secured differently than workstations to protect the protect the information they contain.

- **Endpoints**
    - End of network communication link.
    - One end is often server and other end is often a client making a request to use network resource.

    - An endpoint can be another server, desktop workstation, laptop, tablet, mobile phone, or any other end user device.

- **Fax Machines**
    - A fax machine scans a document, converts the image into audio tones, and sends those tones over a standard telephone line.
    - The receiving machine listens to the tones and reconstructs the image, printing a copy of the original document.

- **Bridges** (OSI Layer 2)
    - A network bridge connects two different parts of the same local network (LAN) and makes them act as a single, larger network.
    - It operates at the **Data Link Layer (Layer 2)** of the OSI model, using MAC addresses to decide whether to forward traffic between the two segments, which helps reduce congestion.

- **Modems** (OSI Layer 1)
    - A modem converts the digital signals from a computer into analog signals that can travel over a transmission line (like a phone or cable line).
    - Its name stands for **Mo**dulator-**Dem**odulator, and it operates at the **Physical Layer (Layer 1)** of the OSI model.

- **Access Points (APs)** (OSI Layer 2)
    - An access point allows wireless devices (like laptops and phones) to connect to a wired network, essentially creating a Wi-Fi network.
    - It functions like a bridge, connecting the wireless network to the wired network, and operates at the **Data Link Layer (Layer 2)**.

Other Networking Terms:

- **Ethernet**
  - Ethernet (IEEE 802.3) is a standard that defines wired connection of networked devices.
  - Standard defines the way data is formatted over the wire to ensure disparate devices can communicate over the same cable.

Device Address:

- **Media Access Control (MAC) Address**
  - Every network device is assigned a MAC address.
  - Example 00-13-02-1F-58-F5. First 3 bytes (24 bits) of adress denote vendor or manufacturer of the physical network interface.
  - No two devices can have same MAC address in same local network.

- **Internet Protocol (IP) Address**
  - Unique logical address.
  - Can be same within different local networks (Private).
  - Divided in two types private and public.

Networking Models:

Provide a framework for understanding how different components of network interact and communicate.

Goals in network and security terms:

- Provide reliable, managed communication between hosts and users.
- Isolate functions in layers.
- Use packets as basis of communication.
- Standardize routing, addressing and control.
- Allow layers beyond internetworking to add functionality.

The most basic form, a network model has at least two layers:

- **Upper Layer** (Application - OSI Layer 7, 6 and 5)
    - Responsible for managing integrity of a connection and controlling the session as well as establishing, maintaining and terminating the session.
    - Transform data recieved from the application layer into a format that any system can understand.
    - Allows application to communicate and determine wheather a remote communication parner is available and accessible.
- **Lower Layer** (Transport - OSI Layer 4, 3, 2 and 1)
    - Responsible for recieving bits from the physical connection medium and converting into a frame.
    - Frames are grouped into standardized sizes.

Open Systems Interconnection Model (OSI):

- **Application Layer** → It provides network services to user applications like web browsers and email clients.
    - Examples - **HTTP, HTTPS, FTP**
    - Possible Attacks - SQL injection & XSS.
    - Prodocol Data Unit - **Data**

- **Presentation Layer** → It handles data formatting, encryption, compression, and character set conversion.
    - Examples - **JPEG, MPEG, SSL/TLS**
    - Possible Attacks - Encryption vulnerabilities & Format manipulation.
    - Prodocol Data Unit - **Data**

- **Session Layer** → It establishes, manages and terminates session. Syn data transfer with checkpoints.
    - Examples - **NetBIOS, SQL, RPC**
    - Possible Attacks - Session hijacking.
    - Prodocol Data Unit - **Data**

- **Transport Layer** →**It** ensures data arrives complete and in the correct order.
    - Examples - **TCP and UDP**
    - Possible Attacks - DoS & Port scanning.
    - Prodocol Data Unit - **Segments**

- **Network Layer** → It determines the best path for data to travel between different networks using IP addresses.
    - Examples - **IP, ICMP, OSPF**
    - Possible Attacks - IP Spoofing & Man-in-the-middle attack.
    - Prodocol Data Unit - **Packets**

- **Data Link Layer** → It packages data into frames and ensures reliable delivery between directly connected devices using MAC addresses.
    - Examples - **Switches, bridges, WAPs, Ethernet**
    - Possible Attacks - Mac spoofing & ARP Poisoning.
    - Prodocol Data Unit - **Frames**

- **Physical Layer** → It handles the actual physical transmission of raw bits (1s and 0s) through cables, fiber optics, or radio waves.
    - Examples - **Cables, Radio waves, Hubs**
    - Possible Attacks - Physical attacks like cutting cable, sniffing signals.
    - Prodocol Data Unit - **Bits**

Encapsulation occurs when data moves 7 → 1 and vice-versa when 1 → 7 (Decapsulation).

Transmission Control Protocol / Internet Protocol:

- Platform independet protocol based on open standards.
- Designed for ease of use rather than security.

Architecture layers:

- Application Layer - Defines protocol for transport layer. (OSI Layer 7, 6 & 5)
- Transport Layer - Permits data to move among devices. (OSI Layer 4)
- Internet Layer - Create / insert packets. (OSI Layer 3)
- Network Interface Layer - How data moves through the network. (OSI Layer 2 & 1)

Internet Protocol Address:

- **IPv4** (32-bit)
  - Subdivided into two parts Network and Host. Network number assigned by external organization such as ICANN.
  - Have two types Public and Private.
  - Private IPv4 range:
    - 10.0.0.0 → 10.255.255.254
    - 172.16.0.0 → 172.31.255.254
    - 192.168.0.0 → 192.168.255.254
  - 127.0.0.1 is Loopback address.

- **IPv6** (128-bit)
  - IPsec is improved.
  - Improved Quality of Service (QoS).
  - Uses Hexadecimal range (0000-ffff).
  - Can be shortened by omitting zeros.
  - ::1 is loopback address.
  - Range 2001:db8:: to 2001:db8:ffff:ffff:ffff:ffff:ffff:ffff is reserved for documentation use.

IPv6 Shortening:

1. Remove leading zeros in each block:

- Example: `2001:0db8:0000:000b:0000:0000:0000:001A` becomes `2001:db8:0:b:0:0:0:1A` after dropping all leading zeros from each section.

2. Replace consecutive blocks of zeros with double colons (`::`), but only once:

- Example: `2001:db8:0:b:0:0:0:1A` (from above) can be compressed further by replacing the longest stretch of consecutive zeros with `::`, giving: `2001:db8:0:b::1A`.
- You can use `::` only one time in an address, or it would be unclear how many blocks are skipped.

Ports and Protocols (Applications and Services):

- **Physical ports**
  Routers, switches, servers, computers, etc. to which you can connect wires to create a network.
- **Logical ports**
  Also called socket. This allow single IP address to support multiple simulteneous communication.
- **Well known ports (0-1023)**
  Related to common protocols that are the core of TCP / IP model.
- **Registered ports (1024-49151)**
  Often assosiated with propriatory applications from vendors and developers.They are approved by Internet Assigned Numbers Authority (IANA).
- **Dynamic or Private ports (49152-65535)**
  Ports that are not pre-assigned to services. They are used for temporary connections.

Secure Ports:

- **File Transfer Protocol (FTP)**
  - Insecure Port - 21
    - Transmits usernames and passwords in plaintext, making it vulnerable to intercept.
  - Secure alternative - **Secure File Transfer Protocol (SFTP) 22**
    - Uses SSH to encrypt data during transmission, ensuring secure file transfers.

- **Telnet**
  - Insecure Port - 23
    - Provides text-based terminal access but lacks encryption, exposing sensitive data like login credentials.
  - Secure alternative - **SSH 22**
    - SSH encrypts communication, making it secure for remote access and command execution.

- **Simple Mail Transfer Protocol (SMTP)**
  - Insecure Port - 25
    - Sends in plaintext, which can be interpreted or spoofed.
  - Secure alternative - **with TLS on port 587 or SMTPS on port 465**
    - Uses encryption to protect email communications.

- **Time Protocol**
  - Insecure Port - 37
    - (RFC-868) lacks error handling is vulnerable to exploitation.
  - Secure alternative - **NTP (Network Time Protocol) 123**
    - Accurate time synchronization with enhanced security features.

- **Domain Name System (DNS)**
  - Insecure Port - 53
    - Queries are typically unencrypted. (DDos)
  - Secure alternative - **over HTTPS (DoH) or over TLS (DoT) 853**
    - Encrypt DNS queries for added security.

- **HTTP**

- Insecure Port - 80
    - Transmits web traffic in plaintext.
- Secure alternative - **HTTPS 443**
    - Encrypts using SSL / TLS.

- **Internet Message Access Protocol (IMAP)**
    - Insecure Port - 143
        - Without encryption allows email data to be intercepted.
    - Secure alternative - **IMAPS 993**
        - Uses SSH / TLS for secure email retrieval.

- **Simple Network Management Protocol (SNMP)**
    - Insecure Port - 161 / 162 (SNMP v1/v2)
        - Lack encryption and authentication.
    - Secure alternative - **SNMP v3**
        - Uses authentication and encryption for secure device management.

- **Server Message Block (SMB)**
    - Insecure Port - 445
        - Outdated and vulnerable to exploits like Eternal blue (ransomware).
    - Secure alternative - **SMBv3**
        - Includes encryption and improved security features.

- **Lightweight Directory Access Protocol (LDAP)**
    - Insecure Port - 389
        - transmit directory information in plaintext.
    - Secure alternative - **LDAPS 636**
        - Uses SSL / TLS.

SYN, SYN-ACK, ACK Handshake:

Client → →**SYN** → → Server
Client ← ←**SYN/ACK** ← ← Server
Client → →**ACK** → → Server

Types of Threats:

- **Spoofing -** Pretending to be someone or something to gain unauthorised access. (Can be done against IP address, MAC address, usernames, system names, SSIDs, etc.)
- **Phishing -** Tricking people for providing sensitive information by pretending to be legitimate entity.
- **DoS / DDoS -** Overloading a system with traffic so legitimate users cannot access it.
  - DoS - Single source
  - DDoS - Multiple sources (botnet) attack
- **Virus -** Self-replicating piece of code that spreads without consent. (Propagation & Destruction)
- **Worm -** Self-replicating program that spreads across networks without needing a host file. (Wannacry)
- **Trojan -** Malware disguised as legitimate software.
- **On-path Attack (MITM) -** Attacker intercepts communication between two parties, often altering or stealing data.
- **Side-channel Attack -** Exploiting physical signals (like power usage or timing) from devices to steal information.
- **APT -** Long-term, targeted by by skilled hackers, often state-sponsored. Aiming at high value targets like givernments or corporations.
- **Insider Threat -** Threats within an organization.
- **Malware (General term) -** Malicious software designed to harm systems or steal data. (Viruses, worms, trojans, ransomwares, etc.)
- **Ransomware -** Malware that encrypts your data and demands payment for decryption.
- **Rootkit:** A type of malware that hides deep within a computer's system to give an attacker secret, long-term control without being detected.
- **Fragment Attack:** An attack that messes up a network by sending data in broken or confusing pieces, causing the system to crash or fail when it tries to put them back together.

- **Oversized Packet Attack:** A network attack where the attacker sends data packets that are too large, overwhelming the system and causing it to slow down or crash.
- **Code/SQL Injection:** An attack where a hacker inserts malicious code into a website or application to trick it into revealing or deleting sensitive information.
- **XSS (Cross-Site Scripting):** A hacker injects a malicious script into a trusted website, which then runs in the browsers of other users who visit the site, often to steal their data.
- **Buffer Overflow:** An attack where too much data is sent to a program, causing it to "overflow" and overwrite memory, which can lead to system crashes or allow a hacker to run their own code.
- **Privilege Escalation:** An attack where a hacker, already inside a system with limited access, finds a way to gain higher-level permissions (like becoming an administrator) to take full control.

Tools to Identify and Prevent Threats:

- **Intrusion Detection System (IDS) -** A form of monitoring to detect abnormal activity; it detects intrusion attempts and system failures. **(Identifies)**
  - **Host-based (HIDS) -** Monitors activity on a single computer.
  - **Network-based (NIDS) -** Monitors and evaluates network activity to detect attacks or event anamolies.
- **SIEM -** Gathers log data from sources across an enterprise to understand security concerns and apportion resources. **(Identifies)**
- **Anti-malware / Antivirus -** Seeks to identify malicious software or process **(Identifies and Prevents)**
- **Scans -** Evaluetes the effectiveness of security controls. **(Identifies)**
- **Firewall -** Filters network traffic, manages and controls network traffic and protects the network. **(Identifies and Prevents)**
- **IPS (NIPS/HIPS) -** An active IDS that automatically attemts to detect and block attacks before they reach target systems. **(Identifies and Prevents)**

Intrusion Detection System:

- Intended as part of defense-in-depth security plan.
- work and complement with other security mechanisms such as firewall, but can't replace them.
- Primary Goal is to provide a means for timely and accurate response to intrusions.
  - HIDS - Often examine events in more detail than a NIDS can, and it can pinpoint specific files compromised in an attack. They are more costly to manage than NIDSs.
  - NIDS - Can't always provide information about success of an attack.
  - SIEM (Security Information and Event Management) - Gathers log data. Can be used with other components.

Preventing Threats:

- **Antivirus -** Requirement for compliance with the **PCI DSS**
- **Firewalls -** Can manage traffic at Layer **2 (MAC Address), Layer 3 (IP ranges)** and **Layer 7 (API)**. The traditional implementation has been to control traffic at Layer 4
- **Intrusion Prevention System -** Active IDS that can auto attempts to detect and block before threats reach target systems.

On-premises Data Centers:

- Data center / Closets
  - Phone, network, special connections
  - ISP or Telecommunications provider equipment
  - Servers
  - Wiring and / or switch components
- Heating,Ventilation and Air conditioning (HVAC)
- Power
- Fire suppression

Redundancy:
Backup of components. (Batteries, Generators, UPS, Transfer switches)

Memorandum of Understanding & Memorandum of Agreement:
Can also called **Joint Operating Agreements (JOA)**. Similar organizations agree that if one of them faces any emergency then other one will share its resources to let them operate critical functions (BC).
Service Level Agreement (SLA) - Formal contract between a service provider and a customer that clearly defines the specific level of service expected.

Cloud Computing:

- Assosiated with an internet-based set of computing resources, and typically sold as a service provided by a **Cloud Service Provider (CSP)**.
- Scalable, elastic, and easy-to-use for provisioning and development of IT services.

> Definition from NIST:

“A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configuration computing resources (such as networks, servers, storage, application, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction” — NIST SP 800-145

- **Five essential characteristics:**
  1. **Broad Network Access -** Services can be accessed from anywhere with an internet connection using different devices like phones and laptops.
  2. **Rapid Elasticity -** You can quickly and automatically scale your resources up or down to match your needs, so it feels like you have unlimited capacity.
  3. **Measured Service -** You only pay for what you actually use, as the cloud system automatically tracks your consumption of resources like storage and processing power.
  4. **On-demand Self-Service -** Users can get computing resources automatically without needing to ask a human for help.
  5. **Resource Pooling -** A provider's resources are shared among many customers, who don't know the exact location of their data.

- **Three Service Models:**
  1. **SaaS (Software as a Service) -**
     Delivers ready-to-use software applications directly to users over the internet, typically on a subscription basis.
     - **Real Example: Google Workspace (Gmail, Google Docs)** or **Salesforce**, where you use the application directly in your web browser without any installation or maintenance.
  2. **PaaS (Platform as a Service) -**
     Offers a complete platform for developers to build, test, and deploy applications without worrying about the underlying infrastructure.
     - **Real Example: Heroku** or **Google App Engine**, which allows a developer to upload their code and have it run automatically without

managing servers or operating systems.

3. **IaaS (Infrastructure as a Service) -**
   Provides fundamental computing resources like virtual servers and storage over the internet, giving you the building blocks to create your own IT environment.
   - **Real Example: Amazon Web Services (AWS) EC2** or **Microsoft Azure Virtual Machines**, where you rent a virtual server and install your own operating system and applications on it.

- **Four Deployment Models:**
  1. **Public -**
     Computing resources are owned by a third-party provider and offered to everyone over the internet on a shared basis.
     - **Real Example:** Using **Google Drive** for personal file storage or hosting a public website on **Amazon Web Services (AWS)**.
  2. **Private -**
     All computing resources are dedicated exclusively to a single organization, providing greater control and security.
     - **Real Example:** A hospital using its own on-site data center to store sensitive patient records in a secure, isolated environment.
  3. **Hybrid -**
     A mix of public and private clouds that are connected to work together, allowing data and applications to be shared between them.
     - **Real Example:** A retail company using a private cloud to manage sensitive customer payment information while using a public cloud to handle the high traffic of its online store during a holiday sale.
  4. **Community -**
     A cloud environment shared by several organizations that have common goals or requirements, such as security or compliance needs.
     - **Real Example:** Several universities sharing a single cloud platform to collaborate on joint research projects and share educational resources, splitting the costs among them.

Managed Service Provider (MSP):

- Company that manages the IT assets for another company.
- Small and medium sized businesses commonly outsource part or all of their IT functions to an MSP to manage day-to-day operations or to provide expertise in areas the company does not have.
- May also use an MSP to provide network and security monitoring and patching services.
- Today, MSP offers cloud-based service augmenting SaaS solution with active investigation and response activities.
- Like Managed Detection and Response (MDR) service, where a vendor monitors firewall and other security tools to provide expertise in triaging events.
- Some other common MSP implementations are:
    - Augment in-house staff for projects.
    - Utilize expertise for implementation of a product or service.
    - Provides payroll services.
    - Provides Help Desk Service Management.
    - Monitor and respond to security incidents.
    - Manage all-in-house IT infrastructure.

Service-Level Agreement (SLA):

- Agreement between a cloud service provider and a cloud service customer based on a taxonomy of cloud computing specific terms to set the quality of cloud service delivered.
- Characterises quality of the cloud services delivered in terms of set measurable properties specific to cloud computing (business & technical) and a given set of cloud computing roles (Cloud customer, provider and related sub roles)
- The purpose of SLA is document specific parameters, minimum service levels, and remedies for any failure to meet the specified requirements. It should also affirm data ownership and specify data return and destruction details.

Network Design:

- **Network segmentation:** Dividing a network into smaller part subnets (segments) to control traffic flow and isolate sensitive resources.
- **DMZ (Demilitarized zone):** A sub-network acting as a buffer between the internet and internal networks, hosting public-facing services. (eg. Web servers)
- **VLAN:** A logical grouping of devices into separate broadcast domains, regardless of physical location. (By switches)
- **NAC:** Enforces policies to ensure only authorised, compliant devices access the network.

Defense in Depth:

Uses layered approach when designing the security posture of an organization.
Data: Encryption, data leak prevention, identity and access management and data controls.
Application: Data leak prevention, application firewalls and database monitors.
Host: Antivirus, endpoint firewall, configuration, and patch management.
Internal network: IDS, IPS, internal firewalls and network access controls.
Perimeter: Gateway firewalls, honeypots, malware analysis and Demilitarized zones.
Physical: Locks, walls or access control.
Policies procedures and awarness: Administrative controls.

Zero Trust:

- Zero trust networks are often microsegmented networks, with firewalls at nearly every connecting point.
- Places the focus on the assets, or data, rather than the perimeter.

Network Access Control (NAC):

- Security solution that ensures only authorised users or devices can access a network.
- Enhances security, supports compliance and reduces risk from unauthorised access or malware.
- NAC for BYOD (Bring Your Own Device) ensures compliance for all employee owned devices before accessing the network.

Network Segmentation - Demilitarized Zone (DMZ):

- Effective way to achieve Defense in Depth.
- Aims to enhance network security by isolating publicly accessible services, making it harder for attackers to directly reach the internal network.
- Includes a firewall or security gateway to control traffic between the DMZ and the internal network, and another to filter traffic from the external network.
- Services include web servers, email servers, FTP servers, and DNS servers.
- **Web Application Firewall (WAF)** - Has an internal and an external connection like a traditional firewall, with the external traffic being filtered by the traditional or next-gen firewall first.

Segmentation for Embedded Systems and IoT:

Embedded Systems - Network attached printers, smart TVs, HVAC controls, Thermostats and medical devices, etc.
IoT - Internet of Things. Smart home devices.

Microsegmentation:

- Allows for extremely granular restrictions within the IT environment to the point where rules can be applied to indivisual machines and / or users, and these rules can be as detailed and complex as desired. (Limiting IP communatication)
- These are logical rules, not physical rules, and do not require additional hardware or manual interaction with the device.
- This is ultimate end state of the defense-in-depth philosophy; no single point of access within the IT environment can lead to broader compromise.
- In modern environment microsegmentation is available because of virtualization and software-defined networking (SDN) technologies. In cloud the tools for applying this are often called "VPN" or "Security groups".

Virtual Local Area Network (VLAN):

Allows network admins to use switches to create software-based LAN segments, which can segregate or consolidate traffic across multiple switch ports. (VLAN Hopping)

- Uses
  - Separate VoIP
  - Separate data center traffic
  - NAC also uses VLAN

Virtual Private Network (VPN):

A virtual private network (VPN) is not necessarily an encrypted tunnel. It is simply a point-to-point connection between two hosts that allows them to communicate.